D3COY 1.0

TEAM NAME

Unethically(""&Gifted;)

TETHER

Bounded blast radius. Fast detection. Not prevention.

COLLEGE NAME

Dwarkadas J. Sanghvi
College of Engineering

D3COY 1.0 · DJS ISACA · @2026-27

PROBLEM STATEMENT

CLEARANCE: L0 ANCHOR // D3COY-2026

Identity Drift Detection in Autonomous AI Agents

Learn each agent's normal behavior, compare it continuously with its declared role, detect a mismatch while credentials stay valid, explain every alert with a clear risk score, and restrict the agent without disrupting legitimate work.

OUR ANSWER: TETHER. BOUNDED BLAST RADIUS. FAST DETECTION. NOT PREVENTION.

TEAM MEMBER DETAILS

Nihal	<<FILL contact no>>
Shravan	<<FILL contact no>>
Ayush	<<FILL contact no>>
Maitri	<<FILL contact no>>

PROPOSED SOLUTION

D3COY 1.0

In every real incident, credentials were valid and each step was permitted. Tether ignores attack wording, enforcing signed role contracts, provenance taint chains, and authority lineage at the tool boundary.

THE PROBLEM: VALID CREDENTIALS PASS IAM

9.3 CVSS
EchoLeak CVE-2025-32711

700+ Orgs
Salesloft Drift Token Replay

Zero-click M365 Copilot data theft and Salesforce Agentforce CRM exfiltration used valid tokens and allowlisted domains. Standard IAM cannot see post-auth behavioral hijacks.

100% of attack steps passed standard IAM checks

THE EVIDENCE: TEXT & LLM GATES FAIL

>90% Bypass
Adaptive attack success

12/12 Broken
Published defenses

Adaptive attacks bypassed 12 published prompt-injection defenses, including MELON. Embedding-similarity and LLM-judge gates fail as attackers optimize token wording.

>90% bypass on wording & LLM-judge defenses

CORE ARCHITECTURE: STRUCTURAL CONSEQUENCES

1 Root Anchor
Signed L0 contract

0 LLM Gates
<4.2 ms deterministic proxy

The signed Role Contract is the only trusted root of truth. Learned behavior is advisory. Monotonic A+B+C provenance, persistent state taint, and authority lineage enforce the boundary.

100% wording-independent boundary enforcement

HOW TETHER WORKS

01 · ROLE CONTRACT [L0 ANCHOR]

`Pydantic v2 · Ed25519`

Non-learnable spec: purpose, permitted MCP tools, data classes, origin taint map, egress allowlist, byte ceilings, and delegatees.

02 · EMPIRICAL-BAYES BASELINE

`SciPy Dirichlet Priors`

Learns per role blueprint, not per instance. Blends contract priors (κ) with clean history (n), guarding brand-new agents on Action #1.

03 · PERSISTENT PROVENANCE CHAIN

`NetworkX DAG · SHA-256`

Tracks Untrusted Input (A) → Sensitive Read (B) → External Egress (C) across tool calls and memory/scratchpad writes. Meta's Rule of Two live.

04 · CHANGE-TICKET MODULATOR (λ)

`HMAC Webhook Verifier`

Checks novelty against signed deployment tickets (λ=0.15) versus prior untrusted exposure (λ=1.25), eliminating rollout false alarms.

05 · FROZEN-ANCHOR DRIFT BUDGET

`River CUSUM / Page-Hinkley`

Accumulates drift against a frozen role snapshot refreshed only by signed changes, defeating slow "boiling frog" evasion.

06 · EPHEMERAL TOKEN NARROWING

`PyMacaroons · Docker SDK`

Appends capability-stripping caveats at L1 in 0.1 ms. Core workflows stay online.

PROBLEM-TO-MECHANISM ALIGNMENT

ATTACK CHALLENGE	TETHER ARCHITECTURAL MECHANISM	PROCUREMENT AGENT EXECUTION TRACE	
Valid credentials hide attack	Post-auth L1 MCP proxy + data-flow invariants	IAM passes; HR read + external POST **[FLOOR ≥90]**	NO
Indirect prompt injection	Monotonic provenance taint; zero text classifiers	Supplier PDF tags session & scratchpad **[TAINT: +A]**	YES
Sanctioned vs. malicious drift	Signed ticket dampener (λ) vs. taint correlation	λ=0.15 SILENT / post-PDF λ=1.25 ALERT	PARTIAL
Cold start (zero history)	Dirichlet contract prior (n=0) + hard L0 rules	First MCP call guarded **[DAY-1 SAFE]**	YES
Multi-agent delegation chains	Authority intersection (Grant ∩ Contract) + taint	B inherits A's taint and strips scope **[SCOPED]**	YES
Split-session / slow evasion	Persistent state taint + frozen-anchor CUSUM	RAG laundering & low-and-slow drip caught **[0 B LEAKED]**	YES

TECHNICAL APPROACH

D3COY 1.0

> The signed L0 role contract is the only trusted fact. Deterministic structural checks gate execution in <4.2 ms; statistical and CPU-ONNX signals support.

L0 ROLE CONTRACT
NON-LEARNABLE

Signed JSON/Pydantic spec: tools, classes, origin taint, egress, caps, delegatees.

`Pydantic v2 · Ed25519`

L1 MCP GATEWAY
EVENT PROXY

Intercepts every tool/API call. Monotonic T_out = T_in ∪ T_res; tags state writes.

`FastAPI · MCP JSON-RPC`

L2 SIX DETECTORS
PARALLEL ENGINE

3 deterministic + 2 statistical + 1 advisory. Emits s_i in [0,1] + evt_id.

`NetworkX · River · ONNX`

L3 LEGITIMACY (λ)
MODULATOR

Signed ticket vs. taint: λ_i=0.15 explained, 1.0 neutral, 1.25 tainted.

`HMAC Webhook`

L4 NOISY-OR FUSION
RISK ENGINE

Modulated scores + impact m produce Risk [0–100] and Confidence.

`NumPy · SQLite SHA-256`

L5 ENFORCEMENT
GATEWAY CAVEATS

5-rung response: token caveats or container reset directly at L1.

`PyMacaroons · Docker`

`L1 APPEND-ONLY AUDIT LEDGER / SQLite WAL + SHA-256 Chain`

`evt_id · prev_sha256 · agent_id · role_v · session_id · delegation_dag · mcp_tool · resource_class · egress_host · bytes_out · taint_state: {UNTRUSTED | SENSITIVE | CLEAN}`

L2 / SIX DETECTORS

Contract Invariant
`DETERMINISTIC · w = 0.90`

Out-of-scope resource class, MCP tool, destination host, or per-call/window byte ceiling. Pydantic strict check.

Rule-of-Two Provenance
`DETERMINISTIC · w = 0.90`

Session or inherited memory holds Untrusted (A) + Sensitive (B), then attempts External Egress (C). NetworkX taint DAG.

Delegation Intersection
`DETERMINISTIC · w = 0.70`

Effective_Auth = Parent_Grant ∩ Child_Contract. Flags unseen caller edges and tainted inter-agent payloads.

Role-Level Baseline
`STATISTICAL · w = 0.50`

Dirichlet transition surprisal + robust Median/MAD volume z-scores (SciPy). Trains only on taint-free sessions.

Frozen-Anchor Drift
`STATISTICAL · w = 0.50`

Page-Hinkley / CUSUM (River) against frozen role snapshot, plus sliding destination byte budget.

Purpose Alignment
`ADVISORY · w = 0.20`

Local FastEmbed CPU bge-small ONNX action-to-role cosine similarity. Never gates execution; triage only.

L3/L4 NOISY-OR FUSION & COLD-START MATH

$$\text{Base} = 1 - \prod(1 - \lambda_i \cdot w_i \cdot s_i)$$

$$\text{Score} = \min(100,\ 100 \cdot \text{Base} \cdot m)$$

m in [0.6, 1.4]: sensitivity, reversibility, exposure

$$\theta_{role}(n) = (\kappa \cdot \theta_{prior} + n \cdot x_{clean}) / (\kappa + n)$$

Hard floors: Restricted + Unapproved Egress ≥90
Completed A+B+C Chain ≥90

$$\text{Confidence} = \text{Maturity}(n) \cdot \text{Signal_Agreement}$$

`< 4.2 ms Gate`



SOC TELEMETRY ALERT CONSOLE

`SEV: CRITICAL · SCORE: 94/100` — `Confidence: 0.91 · Rung 5: Isolate`

```
evt_104 [08:14:02.11] read(supplier_q4.pdf) → +A (UNTRUSTED)
evt_109 [08:14:02.49] query(hr_salary_db) → +B (RESTRICTED BREACH)
evt_112 [08:14:02.53] post(ext-drop.io) → +C [BLOCKED AT L1 · 0 B SENT]
```

COUNTERFACTUAL Score drops to 18 (Log Only) under signed HR-Audit Change Ticket (λ=0.15), without prior untrusted PDF ingestion.

Deterministic alert templates prevent secondary prompt injection against SOC analysts.

FEASIBILITY AND VIABILITY

D3COY 1.0

CPU-native open-source primitives: <4.2 ms gate, zero GPU. Evaluation suites: AgentDojo, InjecAgent, MCPTox.

`FastAPI MCP Proxy` `NetworkX Monotonic Taint` `SciPy MAD & River CUSUM` `Meta's Rule of Two` `PyMacaroons Attenuating Tokens` `Suites: AgentDojo, InjecAgent, MCPTox`

TWO-PHASE ENGINEERING GANTT

PHASE 1 / CORE MVP PHASE 2 / STATISTICAL & MULTI-AGENT MESH

- M1 · Signed L0 Schema & FastAPI L1 Proxy
- M2 · Contract Check & NetworkX A+B+C Taint
- M3 · Modulated Noisy-OR & Macaroon Caveats
- M4 · Deterministic Replay Demo & SOC UI

PHASE 1 MVP DELIVERABLE CUT LINE (LIVE DEMO TARGET)

- M5 · Empirical-Bayes Priors & River CUSUM
- M6 · Cross-Agent Authority Intersection Mesh

7-SCENARIO CONTAINMENT ANALYTICS

SCENARIO	TRIGGER GATE	STEPS TO BLOCK	TARGET OUTCOME
1. PDF Injection → HR → POST	Rule of Two (A+B+C)		0 B Leaked · Blocked Step 3
2. MCP Tool Schema Poisoning	L0 Contract Invariant		0 B Leaked · Blocked Step 1
3. Stolen-Token Host Replay	Context + MAD Volume Z		Quarantined · Step 2 (Rung 4)
4. Multi-Agent Taint (A → B)	Grant ∩ Contract + DAG		Scoped at B · Step 2 (Rung 3)
5. Low-and-Slow Drip Leak	Frozen Anchor CUSUM		Bounded < Sliding Window Cap
6. Semantic Argument Mimicry	Resource/Egress Floor		0 B Leaked · Blocked Step 3
7. Signed Workflow Upgrade	λ=0.15 Ticket Webhook		0 False Alerts · 100% Utility

SYSTEM PERFORMANCE & DESIGN TARGETS

< 4.2 ms
L1 GATE LATENCY BUDGET
100% CPU-native Python + ONNX. Zero LLM calls in enforcement.

0 Bytes
UNAPPROVED RESTRICTED EGRESS
Hard floor (≥90) severs socket before payload transmission.

FP / 1,000
SIGNED-ROLLOUT FP METRIC
Benign + signed-change sessions with λ=0.15 modulation.

100% Linked
SHA-256 AUDIT TRAIL
Every evt_id cryptographically chained inside SQLite WAL.

EVASION → DEFENSE → BOUNDED GUARANTEE

Semantic Mimicry	L0 + A+B+C resource/egress invariants	Trapped inside benign role scope
Split-Session Laundering	L1 persists taint_origin hash on scratchpad/RAG writes	Cross-session taint inherited
Low-and-Slow Drip	Frozen anchor + River CUSUM + window byte quotas	Cumulative exfiltration capped
Baseline Poisoning	Updates require taint == CLEAN & score <30 + human sign-off	Zero self-poisoning loop
Explainer Subversion	Advisory ONNX w=0.2 cannot override floors; fixed templates	Immune to secondary injection

6-PILLAR PRODUCTION TECH STACK

L0 CONTRACT
`Pydantic v2 · JSON Schema · Ed25519`

L1 GATEWAY
`FastAPI · Anthropic MCP SDK · httpx`

L2 GRAPH/STATS
`NetworkX DAG · River CUSUM · SciPy MAD`

L2 ADVISORY
`FastEmbed (CPU bge-small-en ONNX)`

L4 LEDGER
`NumPy Noisy-OR · SQLite SHA-256 WAL`

L5 & SOC UI
`PyMacaroons · Docker SDK · React + WS`

IMPACTS AND BENEFITS

D3COY 1.0

Bounded blast radius plus sub-5ms containment, preserving core business utility while severing exfiltration chains.

SAME INCIDENT, TWO OUTCOMES

WITHOUT TETHER

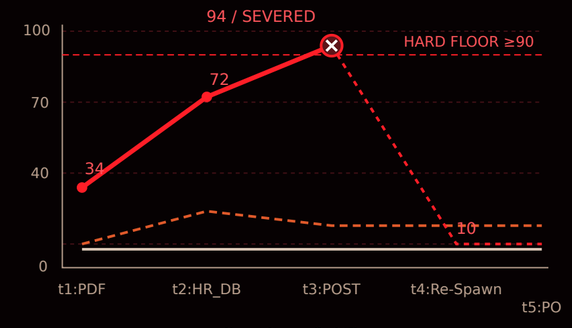
1. **Poisoned Supplier PDF**
   IAM: Valid
2. **Queries HR Salary Share**
   IAM: Valid
3. **POSTs to Allowed/Ext Host**
   IAM: Valid
4. **BREACH: 100% HR DATA EXFILTRATED**

WITH TETHER

1. **Supplier PDF Read**
   L1 Tag: UNTRUSTED [+A]
2. **HR Share Query**
   L2: Out-of-Contract + Taint [A+B]
3. **External POST Intercepted**
   SEVERED AT L1 · SCORE 94 ≥ FLOOR 90
4. **CLEAN PO & PRICING CONTINUES**
   100% CORE UTILITY

LIVE CONTAINMENT TELEMETRY & 5-RUNG BINDING

SESSION RISK TRAJECTORY



Signed change settles at 18 (Log Only).
Benign score: 8. Attack severed at L1.

R1 (<30)	**LOG ONLY**
100% Scope · SQLite log	
R2 (30–59)	**STEP-UP HOLD**
85% Scope · Hold 1 call; benign tasks run	
R3 (60–79)	**NARROW TOKEN**
45% Core Scope · PyMacaroons caveat	
R4 (80–91)	**QUARANTINE**
20% Scope · Flush context; Docker clean spawn	
R5 (≥92)	**ISOLATE ID**
0% Revoked · Revoke & freeze	

STAKEHOLDER VALUE

AGENT OWNERS & SPONSORS

Worst-case blast radius mathematically capped by L0 contract. Utility Preserved stays high.

SOC & INCIDENT RESPONSE

Deterministic score, confidence, evt_id timeline, delegation lineage, and counterfactual.

MULTI-AGENT ECOSYSTEMS

Automatic taint propagation + authority intersection stop lateral agent-to-agent contagion.

ISACA & COMPLIANCE AUDITORS

Hash-chained SQLite WAL ledger proves policy enforcement on every MCP call.

STRUCTURAL ADVANTAGE

Day-1 Cold-Start Protection
Role Baselines Survive Container Restarts
Zero Reliance on Prompt Wording

USP AND FUTURE SCOPE

D3COY 1.0

> Judge the operational consequences at the tool boundary, not the prompt wording.

Immutable Role Contract Anchor
Ed25519-signed Pydantic L0 specification cannot be drifted, overwritten, or sweet-talked by adversarial inputs.

Consequence & Provenance Gating
Meta's Rule of Two (A+B+C) across live MCP calls and SHA-256 memory writes, independent of attack text.

Day-1 Cold-Start Protection
Empirical-Bayes Dirichlet priors (κ) + hard contract invariants guard brand-new agents from Action #1.

Signed Change Modulation (λ)
Webhook verification dampens rollout novelty (λ=0.15), amplifying untrusted-exposure drift (λ=1.25).

Surgical Capability Narrowing
PyMacaroons caveats append at L1 in 0.1 ms. Mission-critical production workflows stay online.

HOW TETHER DIFFERS

SECURITY CAPABILITY	Embedding + LLM Judge	Learned Trace Detectors	Tether (Ours)
Immune to adaptive prompt rewording	NO	PARTIAL	YES
Protected on Action #1 (zero history)	PARTIAL	NO	YES
Zero labeled attack training data needed	YES	NO	YES
Separates signed updates from attacks (λ)	NO	NO	YES
Defeats slow drift & split-session laundering	NO	PARTIAL	YES
Enforces multi-agent authority intersection	NO	NO	YES
Contains blast radius without killing agent	PARTIAL	NO	YES
Sub-5ms CPU gate; 0 LLM in control loop	NO	YES	YES

FUTURE ROADMAP

01 White-Box Adaptive Red-Team
Evaluate adaptive attackers with full knowledge of L2 weights and thresholds.

02 Automated Contract PR Synthesis
Mine clean probation baselines into human-reviewable Git PRs for L0 contracts.

03 Sliding-Window Entropy Quotas
Per-destination rates + Shannon-entropy estimators tighten slow-drip byte ceilings.

04 Distributed MCP Mesh Attenuation
Cross-org Biscuit/Macaroon attenuation across multi-vendor agent chains.

05 Standards Alignment
Map L0/L1 SQLite audit schemas to NIST adaptive authorization and IETF token drafts.

`ROOT: Signed L0 Pydantic Contract` | `GATE: <4.2ms FastAPI + Macaroon Proxy` | `ENGINE: Rule-of-Two DAG + River CUSUM` | `LEDGER: Tamper-Evident SHA-256 SQLite`

Assume the injection lands. Bound what it can do, and see it fast.